

Advanced Security and Privacy

Identitätsmanagement

Dr. Kevin Theuermann

Agenda

- Identifikation und Authentifizierung
- Berechtigungsmodelle
- Identitätsmanagement
- Identitätsmanagement-Modelle
- Identitätsprotokolle

Identifikation und Authentifikation

Digitale Identitäten

- Digitales Abbild einer Person oder eines Objekts in der digitalen Welt
- Anwendungsbereiche:
 - Online-Banking
 - E-Government
 - E-Commerce
 - Unternehmensnetzwerke
 - ...
- Ermöglicht Identifikation und Authentifizierung



Digitale Identität | Teilstücke

- **Eindeutige ID**
 - Ist die Grundlage für eine eindeutige Zuweisung der digitalen Identität zu einer Entität
 - z.B.: Benutzer-ID, Universally Unique Identifier (UUID), etc.
- **Identitätsdaten (Attribute)**
 - Eigenschaften, die eine Person oder ein Objekt beschreiben
 - z.B.: Name, Geburtsdatum, Geschlecht, Geräteinformationen, etc.
- **Authentifizierungs- und Identifikationsdaten**
 - Daten die für eine Anmeldung an einem System mit der digitalen Identität verwendet werden
 - z.B.: Benutzername + Passwort, digitale Zertifikate, etc.



Was ist der Unterschied zwischen einer **Identifizierung** und einer **Authentifizierung**?

Identifizierung

Identification is the association of a personal identifier with an individual presenting attributes.

[Clarke]

- Verbindung zwischen persönlichen Attributen und einem Individuum
 - Z.B.: Name: “Max Mustermann” identifiziert die Person “Max Mustermann”
- Eindeutige Identifizierung
 - Kann durch eine Kombination persönlicher Attribute oder einer eigens erzeugten ID gewährleistet werden
- Traditionell:
 - Reisepass
 - Führerschein, etc.

Authentifizierung

Authentication is proof of an attribute. [Clarke]

The process of verifying a subject's identity or other claim, e.g. one or more attributes. [GINI-SA]

- Prozess der Bestätigung einer behaupteten (digitalen) Identität
 1. Eine Person behauptet bei der Behörde, sie wäre Max Mustermann. (Identifizierung)
 2. Die Behörde verlangt einen Reisepass als Nachweis.
 3. Die Person übergibt den Reisepass mit allen Identitätsdaten. (Authentisierung)
 4. Die Behörde überprüft den Reisepass auf Gültigkeit. (Authentifizierung)
- Online - Ein Identitätsnachweis für eine Authentifizierung kann bspw. Folgendes sein:
 1. Benutzername + Passwort
 2. Fingerprint
 3. Digitales Zertifikat, etc.

Authentifizierungsklassen

- Wissen: “Etwas wissen”
 - Authentifizierung basierend auf nachgewiesenem Wissen
 - z.B. über Passwort, PIN
- Besitz: “Etwas besitzen”
 - Authentifizierung basierend auf nachgewiesenem Besitz
 - z.B. über Reisepass, Smartcards (Bankomatkarte/Kreditkarte etc.)
- Biometrische Eigenschaft: “Etwas sein”
 - Authentifizierung basierend auf physikalischer Eigenschaft
 - z.B. Fingerprint, Gesichtserkennung, Iris Scanner, etc.
- Verhaltensmuster: “Etwas tun”
 - Authentifizierung basierend auf dem Verhalten einer Person
 - z.B. Tippverhalten, Verweildauer in Apps, etc.

Multifaktor-Authentifizierung

- Kombination verschiedener Authentifizierungsklassen zur Erhöhung der Sicherheit
- z.B. Kombination aus Besitz und Wissen (2-Faktor Auth.)
 - Handy-Signatur (**Wissen**: Signatur-PIN, **Besitz**: Schlüsselmaterial, Biometrie: Fingerprint)
 - Online Banking (**Wissen**: Benutzername + PIN, **Besitz**: Mobiltelefon)
- Bei der Wahl von Authentifizierungsmethoden sollte auch die Benutzerfreundlichkeit berücksichtigt werden

Autorisierung

Authorization is a decision to allow a particular action based on an identifier or attribute. [Clarke]

Through authorization, rights are assigned to a digital identity. [GINI-SA]

- Zuweisen/Erteilen von Zugriffsrechten auf Informationen
 - z.B. Lese-/Schreibrechte in einem Dokument
- Wie werden diese Zugriffsrechte in einer Anwendung / App / in einem Unternehmen vergeben?
- Dazu gibt es unterschiedliche Lösungen und daher auch verschiedene **Berechtigungsmodelle**

Berechtigungsmodelle

Berechtigungsmodelle

- **Role Based Access Control (RBAC)**



- Zugriff wird basierend auf Rollen gewährt, die Benutzern zugeordnet sind.
- Eine Rolle definiert Berechtigungen und Aufgaben, die für bestimmte Benutzergruppen gelten (z. B. "Arzt", "Krankenschwester", "Patient")

- **Attribute-Based Access Control (ABAC)**

- Zugriff wird auf Basis von Attributen des Benutzers, der Ressource oder des Umfelds gewährt.
- Attribute können bspw. die zugehörige Abteilung eines Mitarbeiters, der Firmenstandort, oder auch ein spezifisches Gerät (Client) sein.



- **Identity Based Access Control (IBAC)**

- Zugriffsentscheidungen basieren direkt auf der Identität eines Benutzers oder eines Geräts, unabhängig von Rollen oder Attributen.

Berechtigungsmodelle

- **Context-based Access Control (CBAC)**



- Berücksichtigt neben Identität, Rolle oder Attributen auch kontextbezogene Informationen wie Tageszeit, Standort oder Netzwerkbedingungen, um dynamische Zugriffsentscheidungen zu treffen.

- **Mandatory Access Control (MAC)**



- Der Zugriff auf Ressourcen wird durch eine zentrale Autorität nach definierten Sicherheitsregeln festgelegt.
- Die Berechtigungen richten sich nach der Identität einer Person und des Informationsobjekts und zusätzlichen Regeln.

- **Discretionary Access Control (DAC)**



- Der Ressourcenbesitzer entscheidet, wer Zugriff erhält und welche Berechtigungen er vergibt.

Übungsaufgabe

HealthNet ist ein regionaler Gesundheitsdienstleister, der mehrere Krankenhäuser, Kliniken und ein zentrales Diagnostiklabor betreibt. Das Unternehmen bietet eine Vielzahl von Dienstleistungen an, darunter Patientenversorgung, Diagnosetests, Intensivmedizin und eine Online-Telemedizin-Plattform. HealthNet beschäftigt ein großes, vielfältiges Team und steht vor der Herausforderung, den Zugang zu sensiblen Patientendaten sicher und effizient zu gestalten, um gleichzeitig Datenschutz und reibungslose Arbeitsabläufe zu gewährleisten.

- Wählen Sie ein Identitätsmodell (RBAC, ABAC, DAC, MAC, IBAC, CBAC), das Ihrer Meinung nach am besten für MedCare Solutions geeignet ist.
- Begründen Sie Ihre Wahl, indem Sie die Vorteile des gewählten Modells erläutern und mögliche Nachteile der anderen Modelle darlegen, die es weniger geeignet machen.

Berechtigungsmodelle im Vergleich

Modell	Vorteile	Nachteile
Role-Based Access Control (RBAC)	Einfaches Management und klare Zuweisung von Rechten; ideal für Organisationen mit klar definierten Hierarchien.	Eingeschränkt flexibel, da Berechtigungen starr an Rollen gebunden sind.
Attribute-Based Access Control (ABAC)	Sehr flexibel, da Berechtigungen dynamisch auf Attributen basieren; ideal für fein granulare Zugriffssteuerungen.	Komplex in der Verwaltung, da viele Attribute konfiguriert und gepflegt werden müssen.
Identity-Based Access Control (IBAC)	Direkte Kontrolle über spezifische Identitäten, d.h. der Zugriff auf Informationen kann für einzelne Personen explizit gewährt werden.	Schwer skalierbar und pflegeintensiv in großen Systemen, da für jede Identität Berechtigungen festgelegt werden müssen.
Mandatory Access Control (MAC)	Sehr hohe Sicherheit und Kontrolle. Eignet sich ideal für sicherheitskritische Domänen, wie dem Gesundheitswesen, öffentliche Verwaltung, etc.	Schwierig zu verwalten und eingeschränkt anpassbar für dynamische Umgebungen.
Discretionary Access Control (DAC)	Flexibel und benutzerfreundlich, da Berechtigungen direkt von den Eigentümern der Ressourcen vergeben werden.	Benutzer treffen möglicherweise unsichere Entscheidungen; Informationsfluss schwer zu überwachen.
Context-Based Access Control (CBAC)	Geeignet für Zero-Trust-Umgebungen, da Zugriffsentscheidungen kontinuierlich angepasst werden können.	Erfordert komplexe Infrastruktur und kann eine hohe Rechenlast verursachen.

Identitätsmanagement

Identitätsmanagement (IdM)

Identity and access management combines processes, technologies, and policies to manage digital identities and specify how they are used to access resources. [Microsoft]

- Management des Lebenszyklus einer digitalen Identität
- Management von Zugriffsrechten auf Ressourcen
- Verschiedene Dimensionen
 - Innerhalb einer Anwendung/App
 - Innerhalb eines Systems (z.B. eines Unternehmens),
 - Innerhalb eines Netzwerks oder eines Landes

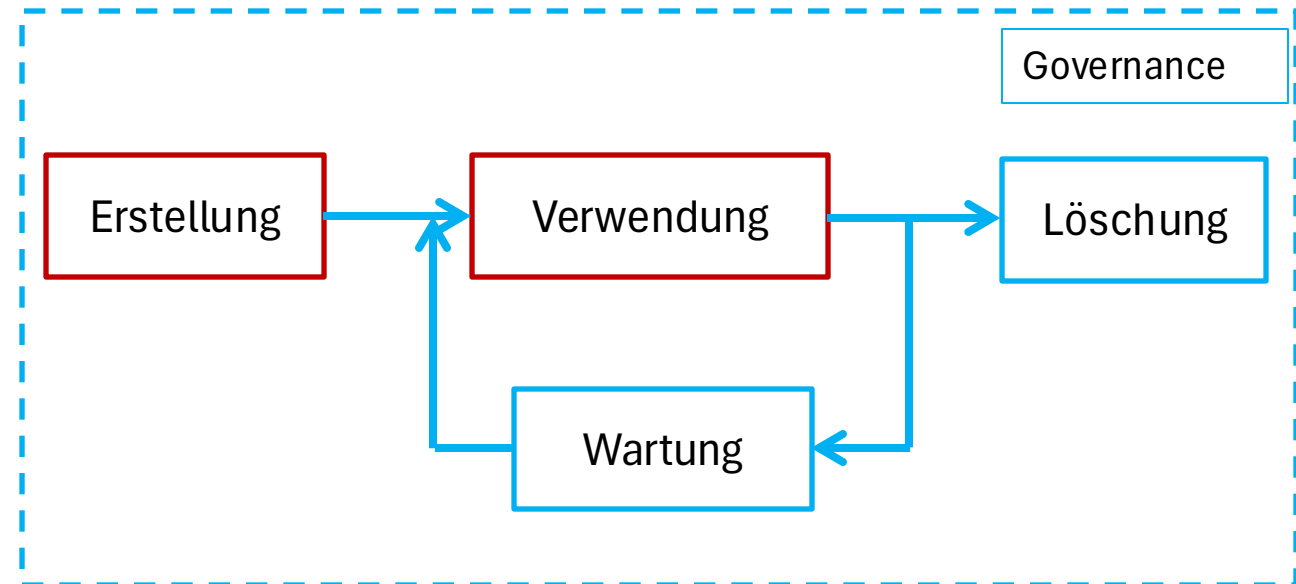
Identitätsmanagement | Lebenszyklus

- Erstellung

- **Registrierungsprozess:** Wie werden Daten zur Erstellung der digitalen Identität erhoben?
- **Erstellung der Anmeldedaten:** Welche Authentifizierungsmittel müssen erstellt werden?
- Wo werden Authentifizierungsmittel gespeichert?
- Prüfung und Verifizierung von Attributen notwendig?

- Verwendung

- **Verwendungsbereich und Autorisierung:**
Auf welche Anwendungen haben die digitalen Identitäten Zugriff?
- **Authentifizierungsprozess:**
Wer führt die Authentifizierung durch?
- Wie läuft der Authentifizierungsprozess ab?
- Welches Protokoll wird für den Authentifizierungsprozess verwendet? (Identitätsprotokoll)



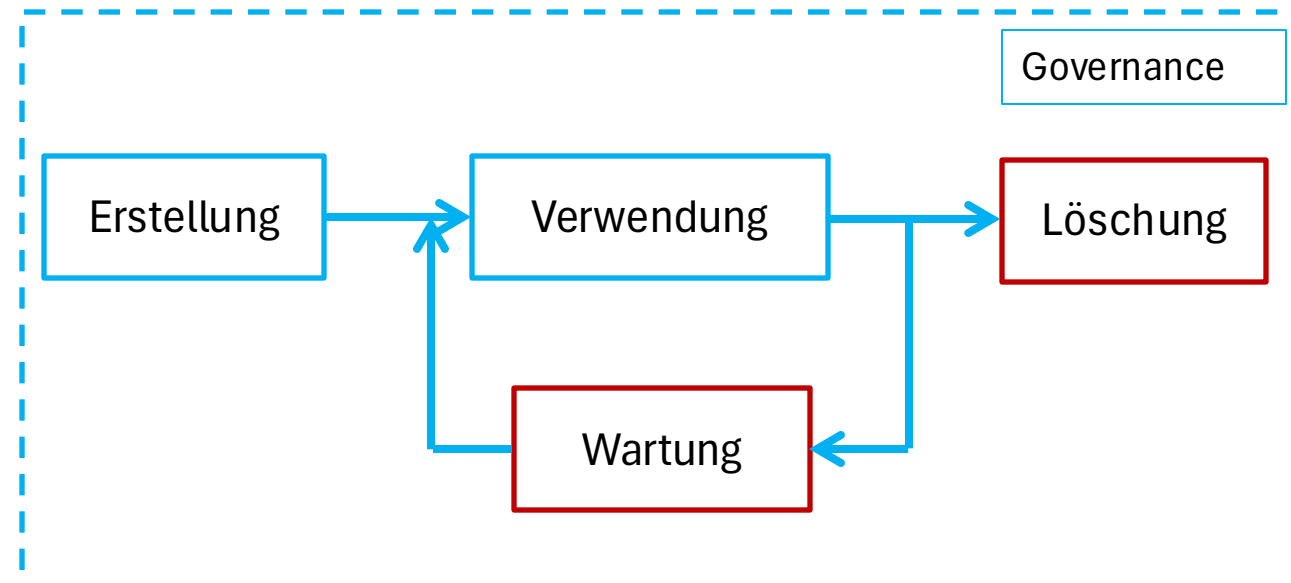
Identitätsmanagement | Lebenszyklus

- **Wartung**

- Können Attribute verändert werden?
Von wem können sie verändert werden?
- Welche Attribute müssen unverändert bleiben?
(z.B. Ids)
- Haben Attribute selbst eine gewisse Lebensdauer? (z.B. Ablauf von Zertifikaten, Lizenzen)

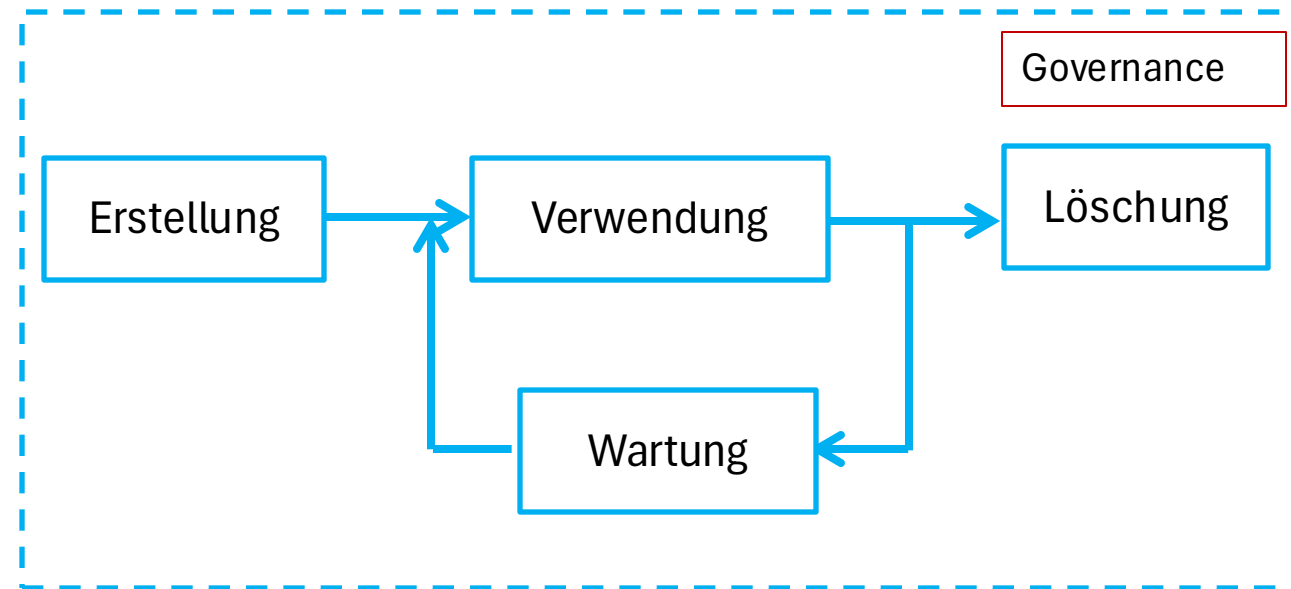
- **Löschung**

- Wie können digitale Identitäten widerrufen werden?
- Werden digitale Identitäten nach einer gewissen Zeit automatisch gelöscht?
- Wie werden betroffene Systeme von der Löschung informiert?
- Wird die Löschung dokumentiert?



Identitätsmanagement | Lebenszyklus

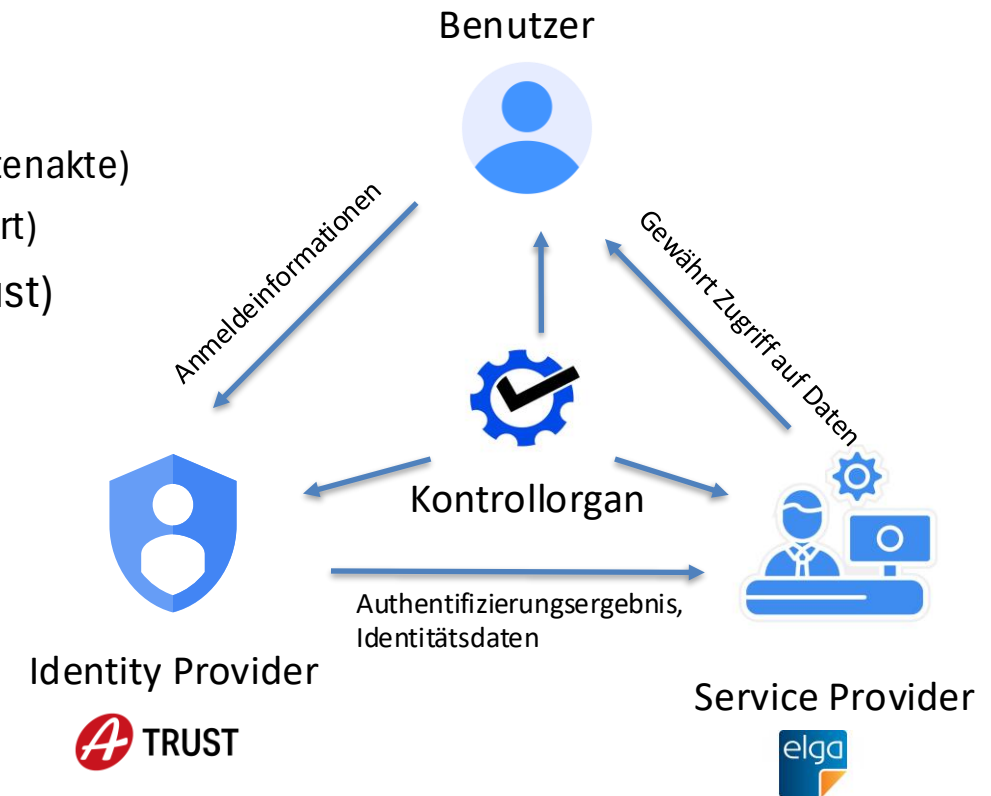
- Governance
 - Erstellung von Richtlinien/Policies für
 - Erstellung, Verwendung, Wartung und Löschung
 - Authentifizierung (gefordertes Sicherheitslevel)
 - Autorisierung (Zugriffsregelungen)
 - Rückverfolgbarkeit einzelner Aktivitäten (Monitoring, Logging)
 - Überwacht die Einhaltung der Policies
 - Basiert oft auf rechtlichen Vorgaben



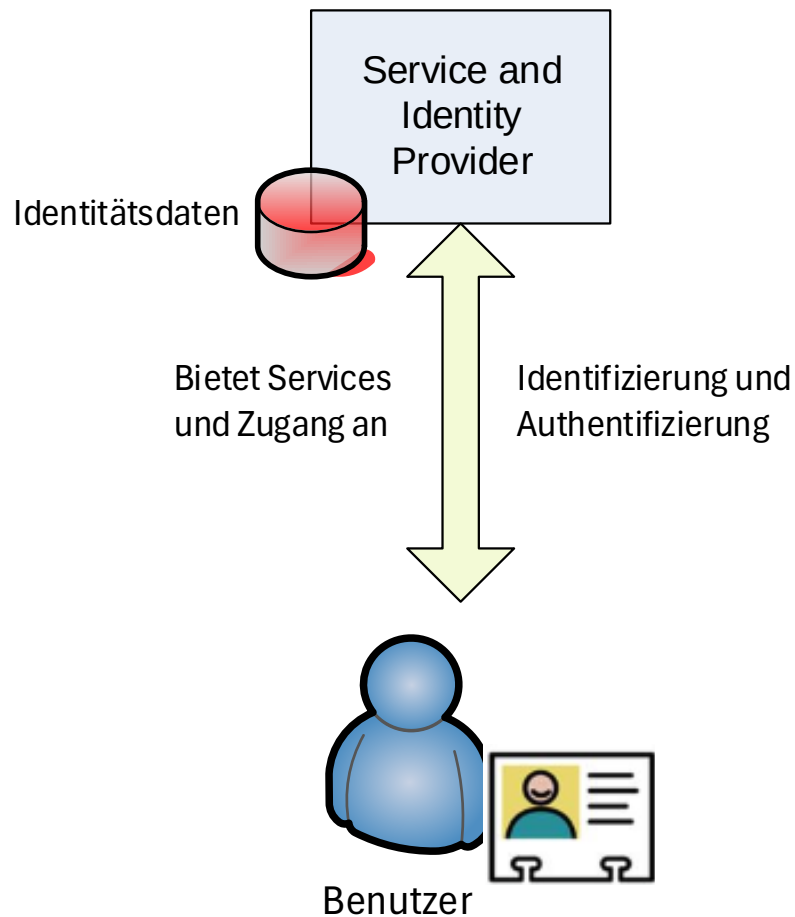
Identitätsmanagement-Modelle

Identitätsmanagement-Modelle | Akteure

- Benutzer = Möchte sich an einem Service anmelden (z.B. ELGA)
 - Benutzer möchte mit seiner digitalen Identität auf Daten zugreifen (z.B. Patientenakte)
 - Übermittelt Authentifizierungsmittel zum Identity Provider (z.B. Name, Passwort)
- Identity Provider (IdP) = Führt die Überprüfung der Person durch (z.B. A-Trust)
 - Identifizierung und Authentifizierung wird durchgeführt
 - Übermittelt Attribute eines Benutzers an Service Provider
- Service Provider = Bietet Service an (z.B. ELGA)
 - Bietet Services/Ressourcen für Benutzer an (z.B. Patientenakte aufrufen)
 - Arbeitet mit Identitätsdaten des Identity Providers
- Kontrollorgan = Überwachungsfunktion (z.B. Staat)
 - Überprüft Einhaltung von Richtlinien/Policies
 - Hat die Möglichkeit zur Durchführung von Prüfungen



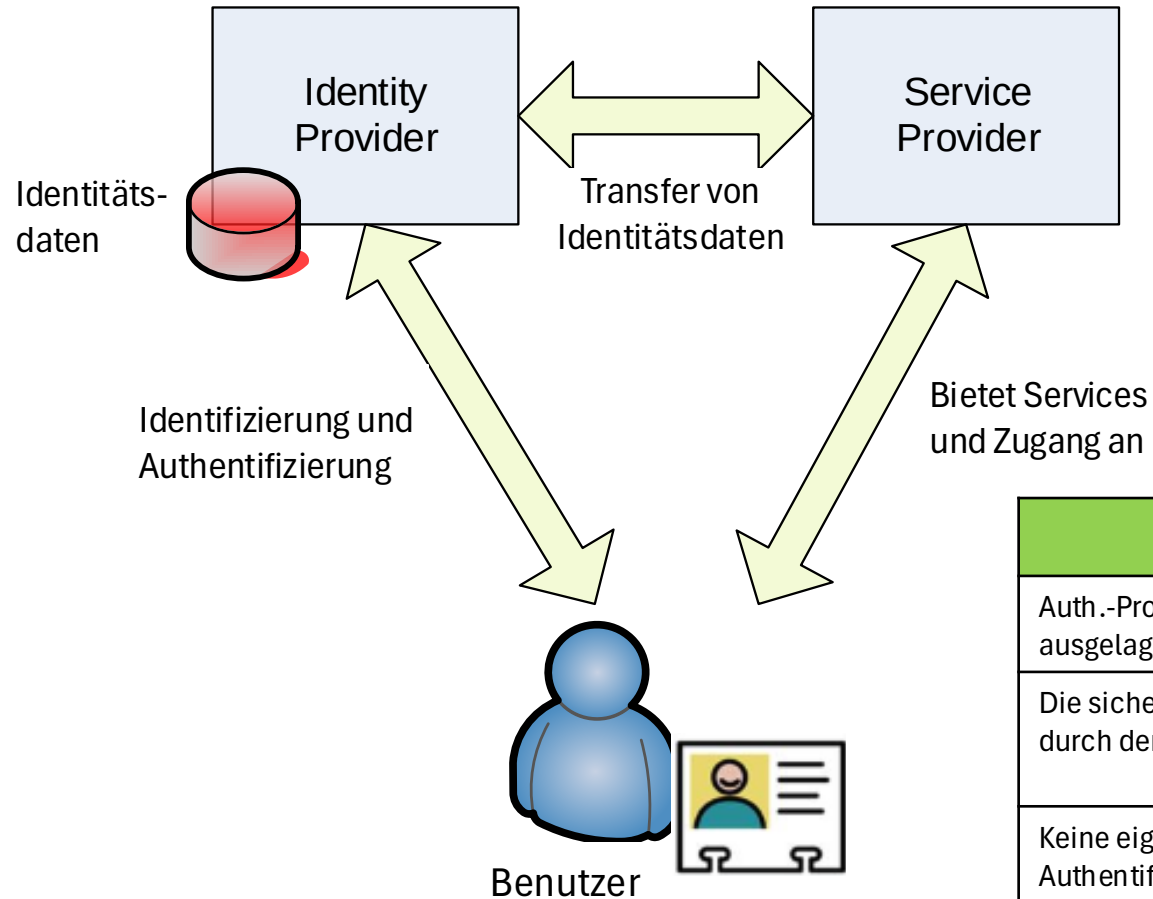
Identitätsmanagement-Modelle | Zentrales Modell



- Service Provider ist auch Identity Provider
- Authentifizierung findet direkt beim Service Provider statt
- Identifizierungsdaten gespeichert und gewartet beim jeweiligen Service Provider

Vorteile	Nachteile
Auth.-Prozess kann selbst bestimmt und geändert werden	Auth.-Prozess muss selbst implementiert werden, was zu erhöhten Kosten führt
Der Service Provider ist unabhängig, was sein Identitätsmanagement betrifft	Es können Fehler in der Implementierung des Auth.-Prozesses auftreten
Ausfälle oder Probleme beim Identity Provider werden schnell erkannt	Der Service Provider ist für alles letztverantwortlich

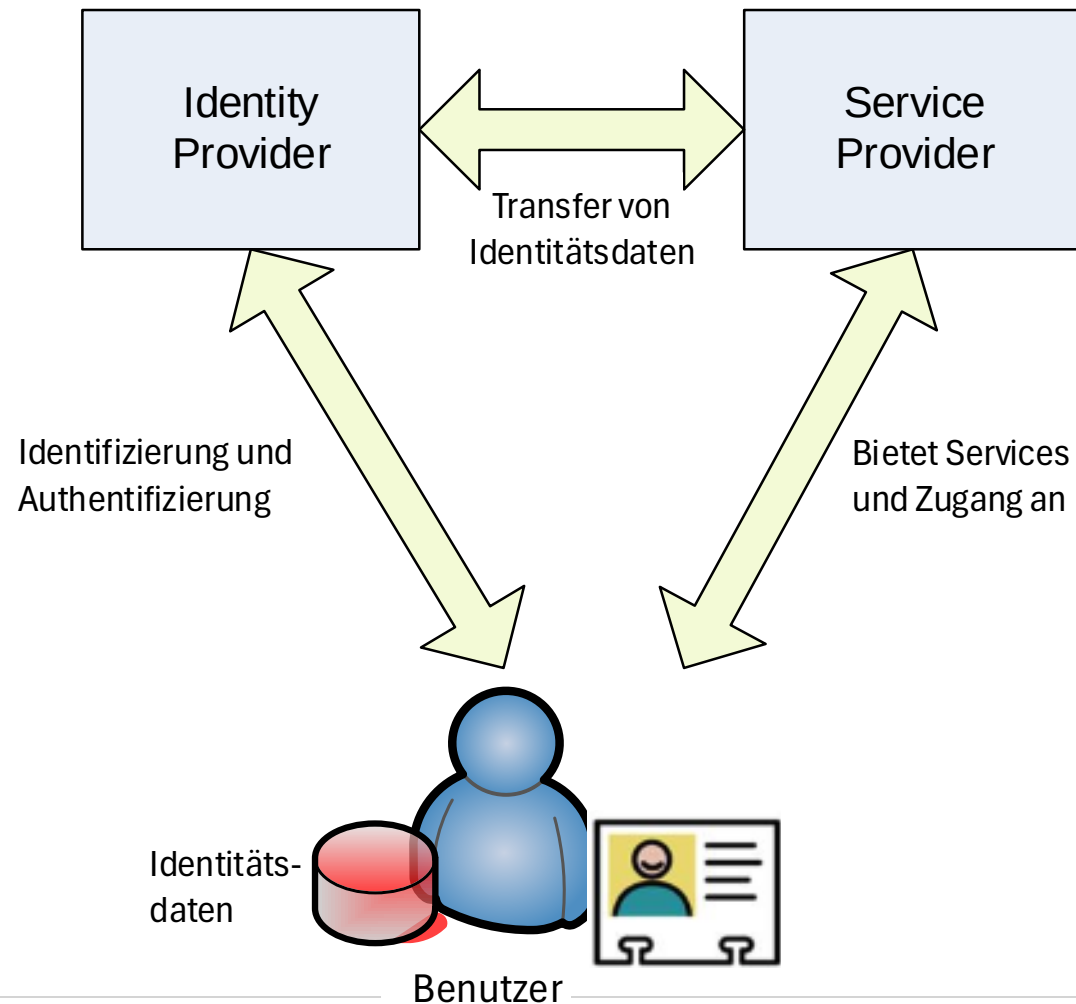
Identitätsmanagement-Modelle | Isoliertes Modell



- Trennung von Identity Provider (IdP) und Service Provider (SP)
- IdP speichert Identitätsdaten
- SP bekommt Identitätsdaten von IdP
- Benutzer: Keine Kontrolle über Transfer von Identitätsdaten

Vorteile	Nachteile
Auth.-Prozess wird an einen Spezialisten ausgelagert	Evtl. Laufende Kosten für die Nutzung des Identity Providers
Die sichere Verwaltung der Identitätsdaten wird durch den Identity Provider durchgeführt	Ein Ausfall des Identity Providers führt dazu, dass Benutzer die Dienste des Service Providers nicht nutzen können
Keine eigene Implementierung der Authentifizierungsprozesse	Die Umsetzung von Änderungswünschen dauert potentiell länger und verursacht höhere Kosten

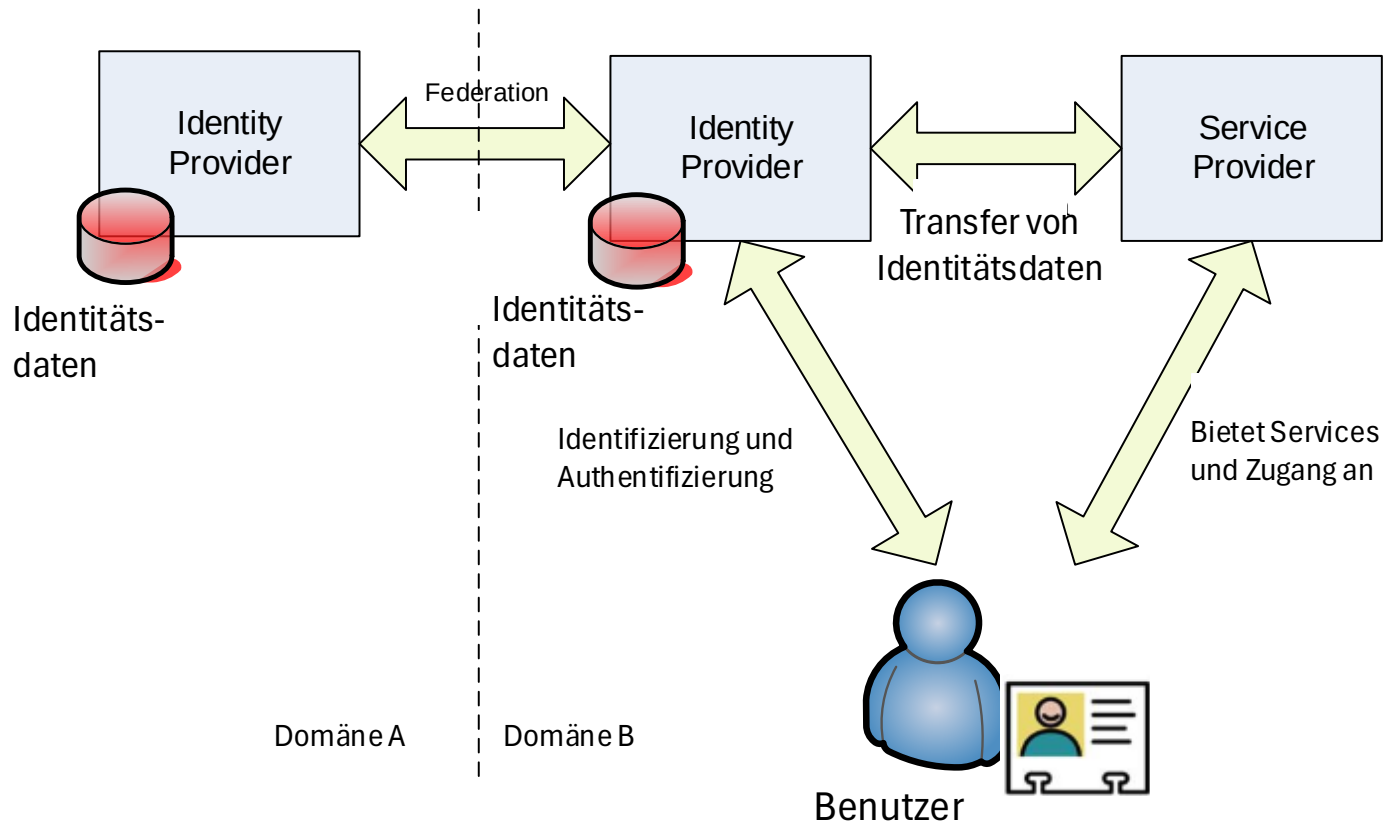
Identitätsmanagement-Modelle | Benutzer-zentriertes Modell



- Identitätsdaten werden beim Benutzer gespeichert
 - Üblicherweise ein Sicherheitstoken (Smartcard, ...)
- Explizite Zustimmung des Benutzers zum Teilen der Daten erforderlich

Vorteile	Nachteile
Der Benutzer hat die Datenhoheit	Der Benutzer kann die Identitätsdaten potentiell verlieren/weitergeben/ändern

Identitätsmanagement-Modelle | Föderiertes Modell



- Identitätsdaten über mehrere IdPs verteilt
- Vertrauensbasis zwischen IdPs erforderlich

Vorteile	Nachteile
Hohe Ausfallsicherheit	Hohe Kosten für den Betrieb und die Synchronisation mehrerer Identity Providers
Die Identitätsdaten von Benutzern können nicht einfach gelöscht werden	Eine Vertrauensbasis zwischen den Identity Providern ist notwendig

Identitätsprotokolle

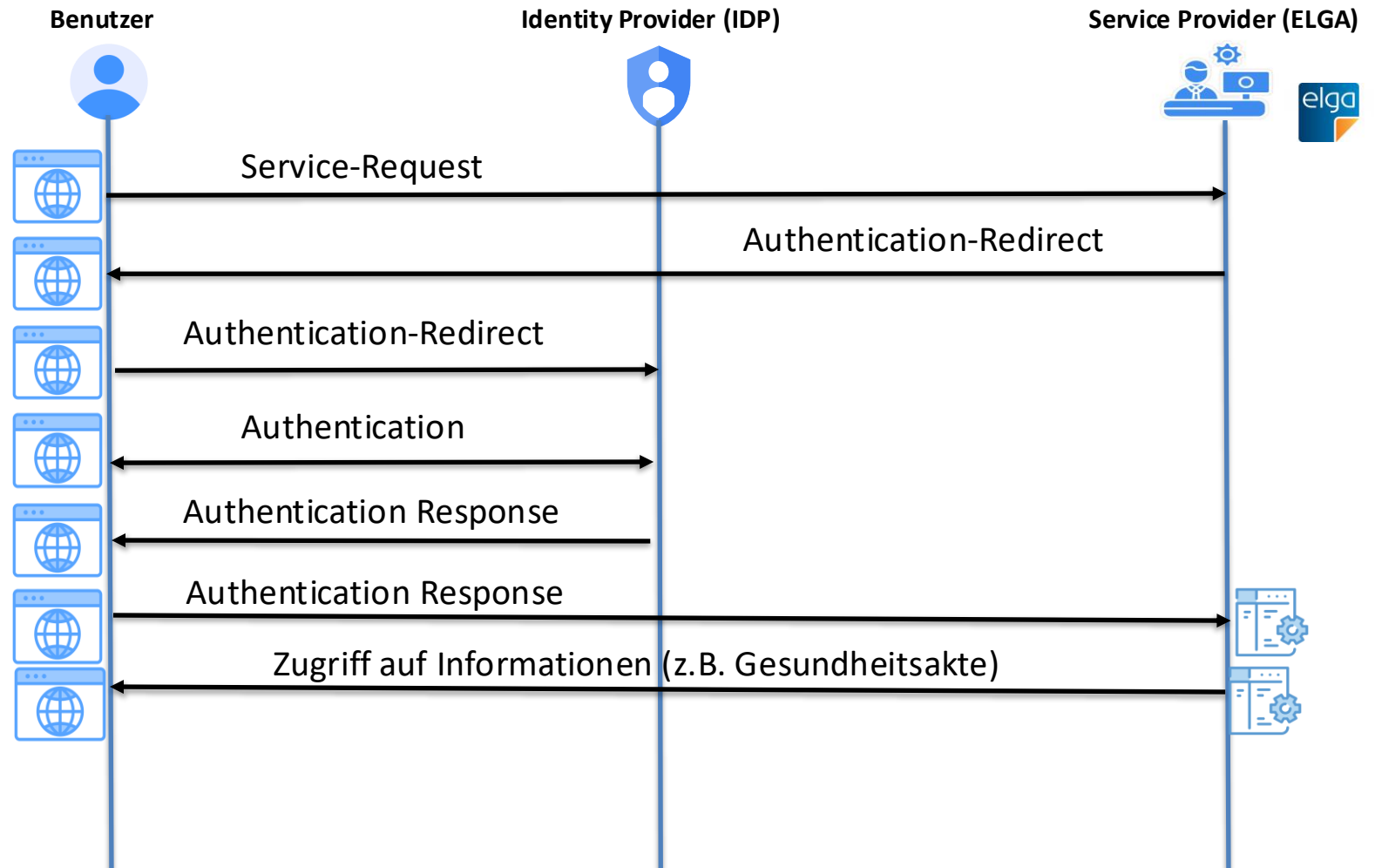
Security Assertion Markup Language (SAML2)

- Identitätsprotokoll mit **XML-basierter Authentifizierung**
- SAML-Assertions (XML Dokument) transportieren Authentifizierung und Benutzerattribute
- Häufige Verwendung für Authentifizierung für älteren Webanwendungen und interne Unternehmensdienste

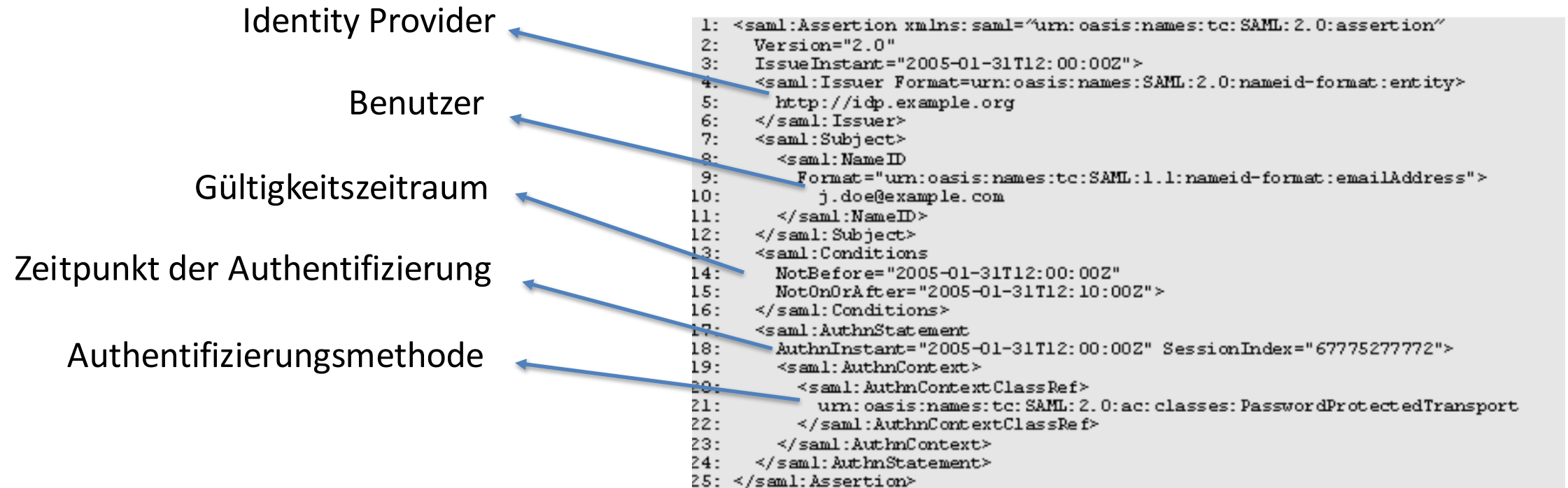


SAML2

- 1. Service Request:** Benutzer will auf seine elektronische Gesundheitsakte zugreifen
- 2. Authentication Redirect:** ELGA fordert eine Authentifizierung und leitet den Benutzer zum IDP weiter
- 3. Authentication:** Der IDP führt die Authentifizierung mit dem Benutzer durch
- 4. Authentication Response:** Der IDP sendet eine Antwort an den Benutzer, die eine SAML-Assertion enthält. Die SAML-Assertion enthält
- 7. Nach einer erfolgreichen Validierung der SAML2 Assertion** gewährt ELGA dem Benutzer Zugriff auf seine Daten.



SAML Assertion



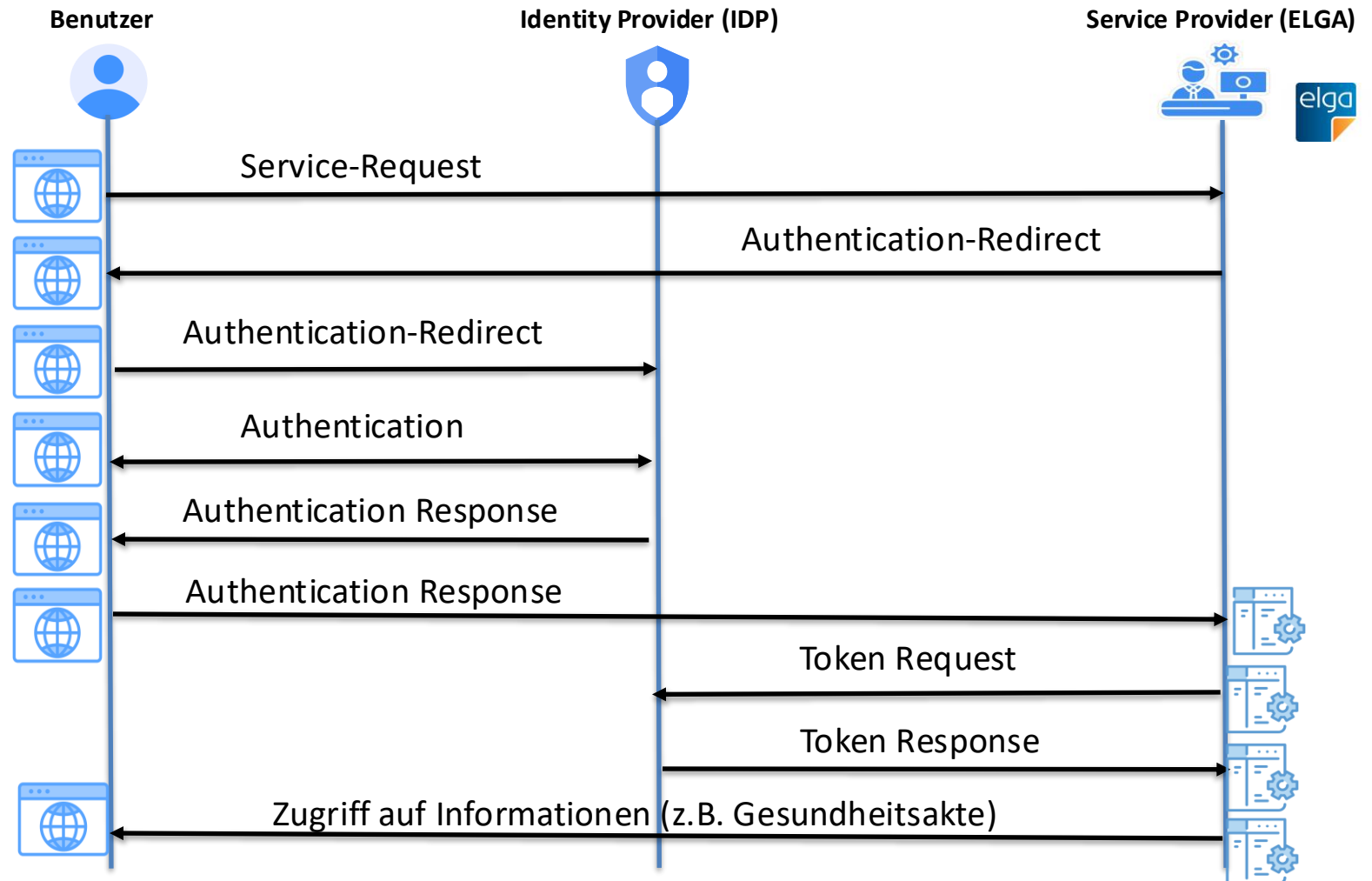
OpenID Connect (OIDC)

- OIDC verwendet **JSON Web Tokens** (JWT), insbesondere das ID-Token, um die Identität des Benutzers zu bestätigen
- Leichtgewichtige Implementierung, was eine einfachere und schnellere Implementierung für Web-/mobile-Anwendungen ermöglicht
- OIDC ist speziell für Web- und mobile-Anwendungen konzipiert und daher flexibler für moderne Anwendungsszenarien als SAML2



OpenID Connect

- 1. Service Request:** Benutzer will auf seine elektronische Gesundheitsakte zugreifen
- 2. Authentication Redirect:** ELGA fordert eine Authentifizierung und leitet den Benutzer zum IDP weiter
- 3. Authentication:** Der IDP führt die Authentifizierung mit dem Benutzer durch
- 4. Authentication Response:** Der IDP sendet eine Antwort an den Benutzer, die einen Berechtigungscode enthält, welcher wiederum an das Backend der ELGA weitergeleitet wird
- 5. Token Request:** Das Backend der ELGA sendet eine Anfrage an den IDP, zur Übermittlung der Identitätsdaten. Dazu wird der Berechtigungscode und ein geheimes Kennwort an den IDP geschickt.
- 6. Token Response:** Der IDP antwortet mit dem ID-Token der die Identitätsdaten enthält.
- 7.** Basierend auf den Identitätsdaten werden die jeweiligen Rechte geprüft und Zugriff gewährt oder abgelehnt.



ID Token

jwt.ms

Enter token below (it never leaves your browser):

[eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiIxMjM0NTY3ODkwIiwibmFtZSI6IkpvaG4gRG9lIiwiaWZwIjoiJG91IiwiaWF0IjoiYjQb2huLmRvZUBleGFtcGx1LnVbSIImF1ZCI6Imh0dHBzOi8vYXBpLmV4YW1wbGUuY29tIiwiaXNzIjoiaHR0cHM6Ly9pZHBzLmV4YW1wbGUuY29tIiwizXhwIjoxNjI1MTI4NjQ0LCJpYXQiOiE2MjUxMjg2NDQsImp0aSI6IjE0MzQzODU0NzEifQ.CV1LR1atZ21PlsVL3keToZye7KFQ01A6JfXq28PF18Q](#)

43

Decoded Token Claims

```
{
  "alg": "HS256",
  "typ": "JWT"
}.{
  "sub": "1234567890",
  "name": "John Doe",
  "email": "john.doe@example.com",
  "aud": "https://api.example.com",
  "iss": "https://idps.example.com",
  "exp": 1625128644,
  "iat": 1625128644,
  "jti": "1434385471"
}.[Signature]
```

Benutzer

Identity Provider

Gültigkeitszeitraum

Advanced Security and Privacy

Identitätsmanagement

Dr. Kevin Theuermann